

Controls and compliance checklist

Controls assessment checklist

Yes	No	Control
	✓	Least Privilege
	✓	Disaster recovery plans
	✓	Password policies
	✓	Separation of duties
✓		Firewall
	✓	Intrusion detection system (IDS)
	✓	Backups
✓		Antivirus software
	✓	Manual monitoring, maintenance, and intervention for legacy systems
	✓	Encryption
	✓	Password management system
✓		Locks (offices, storefront, warehouse)
✓		Closed-circuit television (CCTV) surveillance
✓		Fire detection/prevention (fire alarm, sprinkler system, etc.)

Compliance checklist

Payment Card Industry Data Security Standard (PCI DSS)

Yes	No	Best practice
	✓	Only authorized users have access to customers' credit card information.
	✓	Credit card information is stored, accepted, processed, and transmitted internally, in a secure environment.
	✓	Implement data encryption procedures to better secure credit card transaction touchpoints and data.
	✓	Adopt secure password management policies.

General Data Protection Regulation (GDPR)

Yes	No	Best practice
	✓	E.U. customers' data is kept private/secured.
✓		There is a plan in place to notify E.U. customers within 72 hours if their data is compromised/there is a breach.
	✓	Ensure data is properly classified and inventoried.
✓		Enforce privacy policies, procedures, and processes to properly document and maintain data.

System and Organizations Controls (SOC type 1, SOC type 2)

Yes	No	Best practice
	✓	User access policies are established.
	✓	Sensitive data (PII/SPII) is confidential/private.

- ✓ Data integrity ensures the data is consistent, complete, accurate, and has been validated.
 - ✓ Data is available to individuals authorized to access it.
-

Recommendations:

Botium Toys is missing key security controls, resulting in a weak security posture. To improve the security posture, controls including implementation of strict password policies, separation of duties, and principle of least privilege, regular maintenance and monitoring for legacy systems, setting up Intrusion Detection Systems, creating disaster recovery plans and regular backups, having a centralized password management system, and using encryption to store sensitive data must be put in place.

Moreover, Botium Toys must also address the gaps in compliance with international standards. PII/SPII, including but not limited to Payment Card Information, must be encrypted before being stored. This data also needs to be properly classified, to prevent unauthorized access. Separation of Duties and Least Privilege is also important to adhere to international standards.